УНИВЕРЗИТЕТ У НОВОМ САДУ
ФАКУЛТЕТ ТЕХНИЧКИХ НАУКА

ПРОЈЕКТНА СПЕЦИФИКАЦИЈА

Платформа за интерактивне лабораторијске вежбе из информационе безбедности

Нови Сад, 2026.

Садржај

1 Предмет и опсег спецификације 1
1.1 Нормативност и обележавање захтева 1
2 Корисници, сценарији и права 2
2.1 Правила ауторизације 2
3 Концептуална архитектура и границе модула 3
3.1 Стабилни уговори између модула 3
3.2 Кључни ентитети 4
3.3 Технолошки оквир и заменљивост компоненти 4
4 Каталог функционалних захтева 6
4.1 Управљање налозима и идентитетом 6
4.2 Чланства, курсеви и овлашћења 6
4.3 Каталог лабораторија и тематске области 7
4.4 Ауторски алат и садржај лабораторије 7
4.5 Објављивање, верзије и повлачење 7
4.6 Додела вежби и приступ роковима 8
4.7 Покушаји, одговори и радни простор 9
4.8 Језгро евалуације и резултати 9
4.9 Ручни преглед и повратне информације 10
4.10 Напредак, компетенције и извештаји 11
4.11 Догађаји, ревизија и обавештења 11
4.12 Управљање подацима, приватност и администрација 11
4.13 Типови интерактивних лабораторија 12
4.14 Изоловано извршавање и техничке лабораторије 12
4.15 Интеграције и проширивост 14
5 Типови лабораторијских сценарија 15
6 Кључни случајеви употребе и токови 17
7 Безбедносни и нефункционални захтеви 19
7.1 Претње и границе поверења 19
7.2 Уговор проширивости evaluator-a 20
8 Проверљивост, тестирање и прихватање 21
8.1 Структура тест-сценарија 21
8.2 Интеграционе и регресионе провере 21
9 Речник појмова 22

1 Предмет и опсег спецификације

Предмет ове спецификације је наставна веб-платформа за контролисано решавање интерактивних задатака из информационе безбедности. Систем омогућава наставницима да припреме и објаве лабораторије, студентима да решавају сценарије, а платформи да безбедно сачува покушаје, провери резултате и обезбеди објашњиву повратну информацију.

Основни принципи

- Један дугорочно одржаван производ и један заједнички репозиторијум, са историјом одлука и компатибилним миграцијама.
- Модуларни монолит са јасним границама. Функционалности се могу додавати без мењања туђег интерног стања.
- Изолација корисничких података и провере дозвола на серверу. Клијентски интерфејс није безбедносна граница.
- Нови типови лабораторија користе стабилне уговоре за улаз, сценарио, евалуацију и повратну информацију.
- Објављена ревизија лабораторије је непроменљива за покушаје који су већ започети.
- Заштита система има предност над „реалистичношћу“ лабораторије: у почетку симулације, а касније изоловано извршавање као додатни модул.

Изван обавезног језгра

Аутоматско покретање произвољног студентског кода, јавна изложеност рањивих сервиса, интеграције са стварним институционалним налозима и сложена аналитика нису предуслов за постојање платформе. Ако се уведу, морају бити засебно спецификовани, ревидирани и безбедносно контролисани.

1.1 Нормативност и обележавање захтева

Ознака	Тумачење
Ј — језгро	Неопходна функционалност за стабилну основну платформу.
П — проширење	Планирана функционалност која се може додати када су предуслови испуњени.
Н — напредно	Захтева додатну инфраструктуру, безбедносну анализу или већу зрелост производа.
ID захтева	Стабилна ознака која идентификује захтев кроз измене спецификације.

Ознаке Ј/П/Н разликују основне, проширене и инфраструктурно захтевније функционалности. Оне описују зависности између захтева и не мењају правила приступа или уговоре постојећих модула.

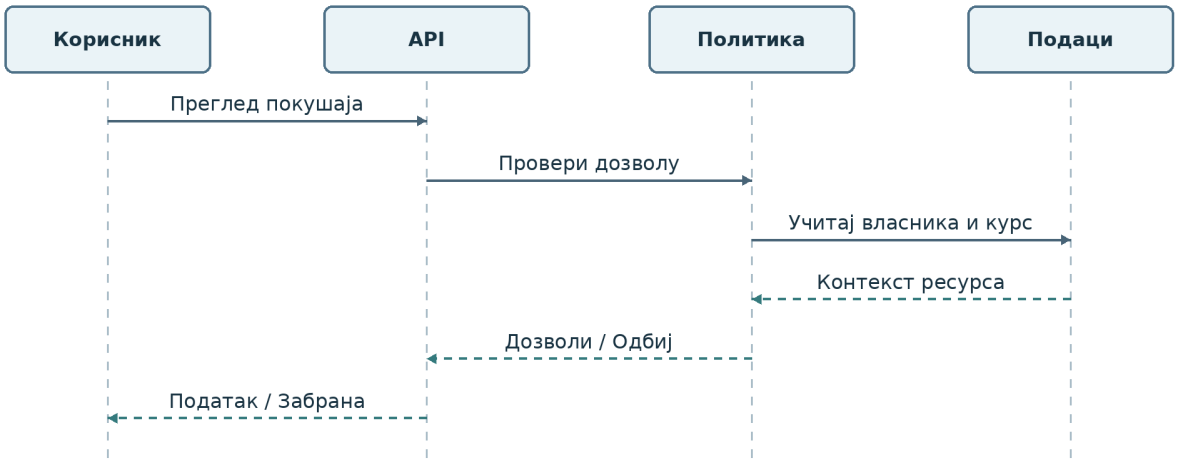
2 Корисници, сценарији и права

Систем разликује глобални статус налога од улоге у конкретном курсу. Једна особа може бити студент у једном курсу и наставник у другом, док техничка администрација не подразумева аутоматско право да чита садржај студентских одговора.

Актер	Овлашћења
Посетилац	Преглед јавног описа платформе и ако је дозвољено, јавног каталога: без приступа одговорима и личним подацима.
Студент	Преглед додељених лабораторија: покретање, решавање и предаја сопствених покушаја. Увид у дозвољену повратну информацију.
Наставник	Управљање додељеним курсевима, лабораторијама и њиховим ревизијама. Преглед покушаја уписаних студената и ручна евалуација.
Сарадник	Само експлицитно делегиране наставничке радње у оквиру курса (нпр. преглед покушаја).
Администратор	Конфигурација система, управљање налозима и техничким стањем. Приступ осетљивим резултатима само уз посебну, евидентирану дозволу.
Сервисни извршилац	Ограничени машински идентитет који обрађује задатке и нема право приступа произвољним налозима.

2.1 Правила ауторизације

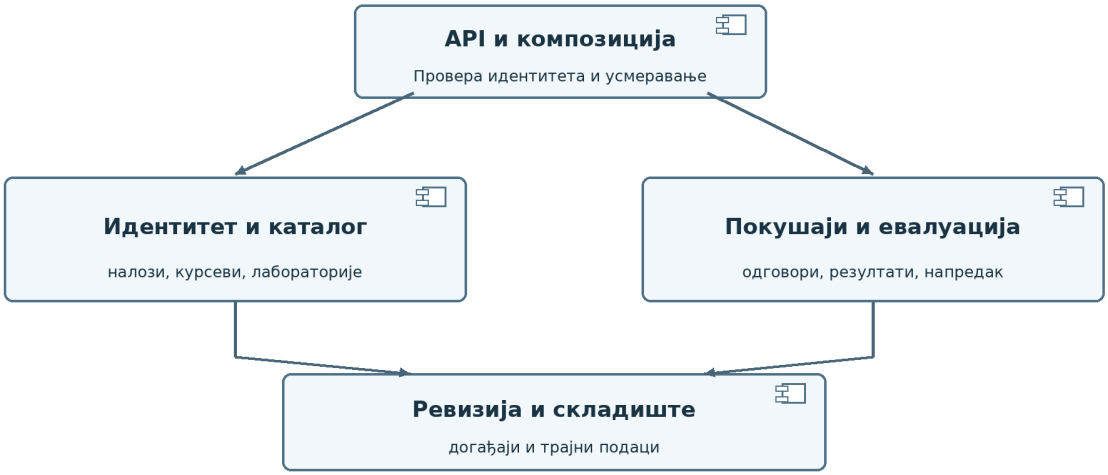
- Одлука о приступу зависи од субјекта, радње, конкретног ресурса, курса, чланства и статуса ресурса.
- Недозвољен приступ одбија се на серверу и не сме да ода садржај туђег покушаја.
- Провера права мора бити поновљена у сваком релевантном API случају употребе.
- Пренос власништва, промена наставника и иступање студента не смеју ретроактивно да измене историјске резултате.
- Привилеговане радње имају ревизорски запис са актером, радњом, временом и исходом, без тајни.



Слика 2.1.1. UML дијаграм секвенце: провера овлашћења за конкретан покушај.

3 Концептуална архитектура и границе модула

Систем је организован као модуларни монолит. Серверска апликација садржи логички изоловане модуле који комуницирају преко јасних интерфејса и контролисаног приступа подацима. Сваки модул чува сопствене инваријанте. Издвајање појединачног модула у засебан процес дозвољено је само уз очуване уговоре и безбедносне границе.

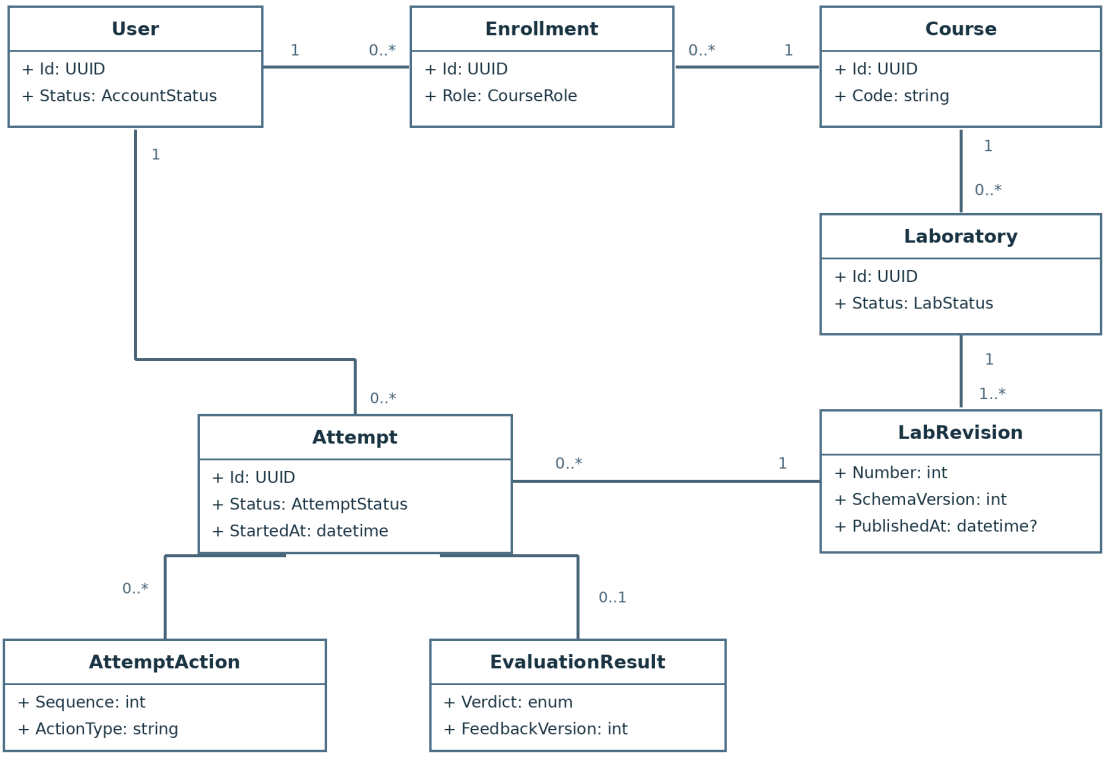


Слика 3.1. UML дијаграм компоненти: границе одговорности.

3.1 Стабилни уговори између модула

Уговор	Подаци / одговорност	Правило
IIdentityContext	Идентификација субјекта и статус налога	Без излагања лозинки, тајни и сирових сесија.
IAccessDecision	Провера права над конкретним ресурсом	Одлука се доноси на серверу. Подразумевано одбијање.
ILabDefinitionReader	Читање тачно одређене објављене ревизије	Не прихвата произвољну измену објављене верзије.
IAttemptStore	Снимање статуса и догађаја покушаја	Идемпотентне операције и контрола конкурентних измена.
ILabEvaluator	Извршавање евалуације дефинисаног типа	Детерминистички резултат за исти снимак података.
IAuditWriter	Структурисани безбедносни запис	Без личних тајни и осетљивих решења.
IExecutionGateway	Извршење изолованог окружења (опционо)	Квоте, timeout, ограничен мрежни приступ, чишћење.

3.2 Кључни ентитети



Слика 3.2.1. UML дијаграм класа: корисник, курс, лабораторија, ревизија и покушај.

Курс представља организациони контекст. Laboratory је трајни идентитет вежбе, а LabRevision означава конкретну објављену варијанту. Сваки Attempt је везан за једну ревизију. EvaluationResult се чува одвојено зато што може настати аутоматском или ручном провером.

3.3 Технолошки оквир и заменљивост компоненти

Референтне технологије дефинишу могућ начин реализације система. Замена клијентског оквира, складишта података или инфраструктурног адаптера не сме да промени доменска правила, одлуке о приступу и уговоре евалуације. Јавни уговори остају верзионисани, а измене података обухваћене миграцијама и регресионим тестовима.

Слој	Предлог	Разлог
Презентација	React / TypeScript	Веб интерфејс студента и наставника, одвојен од пословне логике.
API и модуларни монолит	ASP.NET Core / C#	Јасни случајеви употребе и контроле приступа.
Податке	PostgreSQL	Транзакције, миграције и релације доменских ентитета.
Аутентикација	ASP.NET Core Identity или одговарајући адаптер	Исправно управљање налозима без сопствене криптографије.
Тестови	NUnit + интеграциони тестови	Заштита инваријанти и негативних безбедносних токова.
Извршавање лабораторија	Изоловани runner (опционо)	Напредна функционалност, засебна граница поверења.



Слика 3.3.1. UML дијаграм пакета: зависност проширења од основне платформе.

4 Каталог функционалних захтева

Каталог одређује функционалности платформе. Сваки захтев има јединствену, непроменљиву ознаку, категорију Ј/П/Н и минимални критеријум прихватања. Измене захтева морају бити документоване тако да се може утврдити утицај на већ реализовано понашање, податке и тестове. Идентификатор се не додељује другој намени.

4.1 Управљање налозима и идентитетом

Кориснички налози, пријава, статуси, опоравак приступа и минимални лични подаци.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
IDN-01	Ј	Регистрација налога или административно креирање	Креира се јединствен налог. Постојећи идентификатор се не може поново доделити.
IDN-02	Ј	Безбедна пријава и одјава	После одјаве стара сесија више није употребљива.
IDN-03	Ј	Статуси налога: активан, блокиран, архивиран	Блокиран налог не добија нове приступне сесије.
IDN-04	Ј	Промена лозинке и опоравак приступа	Ресет токен истиче, једнократан је и не открива постојање налога.
IDN-05	Ј	Ограничење броја покушаја пријаве	Прекомерни неуспешни покушаји активирају успоравање/блокаду.
IDN-06	П	MFA за изабране групе корисника	Привилеговани налог не може да заобиђе други фактор када је обавезан.
IDN-07	П	Историја активних сесија и опозив	Опозвана сесија не може да настави захтеве.
IDN-08	Н	Федеративни идентитет преко OIDC	Поновљени идентитет се мапира на један унутрашњи налог, без дуплирања.

4.2 Чланства, курсеви и овлашћења

Организација курсева и група, додела улога и провера власништва над ресурсима.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
ACC-01	Ј	Креирање и архивирање курса	Архивирање спречава нове уписе, а не брише историју.
ACC-02	Ј	Додела студента курсу	Не може се двоструко уписати исти активан члан.
ACC-03	Ј	Додела наставника и сарадника	Измена права важи при следећем захтеву.
ACC-04	Ј	Ауторизација на нивоу конкретног ресурса	Студент не чита покушај другог студента ни директним URL-ом.
ACC-05	Ј	Подразумевано одбијање непознатих акција	Нова акција без политике не даје аутоматски приступ.
ACC-06	П	Групе и ограничена видљивост по групи	Чланови једне групе не виде затворене материјале друге.
ACC-07	П	Привремена делегирана дозвола	По истеку делегације приступ престаје и постоји запис о промени.
ACC-08	Н	Контекстуалне политике приступа	Ни улога ни атрибут сами не заобилазе власништво над ресурсом.

4.3 Каталог лабораторија и тематске области

Преглед, категоризација, претрага и навигација кроз лабораторије.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
LAB-01	Ј	Креирање лабораторије са трајним ID	ID остаје исти кроз ревизије и измене наслова.
LAB-02	Ј	Назив, циљ, тежина, тип, ознаке	Потребна метаполја су валидирана и доступна у каталогу.
LAB-03	Ј	Везивање лабораторије за курс	Није могуће отворити лабораторију ван дозвољеног контекста.
LAB-04	Ј	Видљивост: нацрт, објављена, архивирана	Студент не види нацрт или скривене критеријуме.
LAB-05	Ј	Претрага и филтрирање	Резултати поштују права приступа корисника.
LAB-06	П	Предуслови и логички пут учења	Недоступан задатак јасно приказује услов откључавања.
LAB-07	П	Локализација и приступачне варијанте	Обе језичке варијанте показују исту ревизију и исти evaluator.

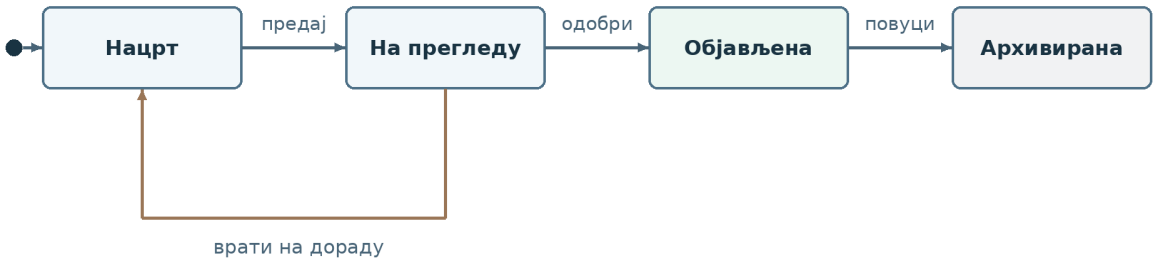
4.4 Ауторски алат и садржај лабораторије

Уређивање сценарија, корака, средстава, тестних података и критеријума успеха.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
AUT-01	Ј	Креирање и измена нацрта	Необјављени нацрт се може мењати без утицаја на постојеће покушаје.
AUT-02	Ј	Структурирани кораци и упутства	Кораци имају стабилан редослед и проверену шему.
AUT-03	Ј	Валидација улазних параметара сценарија	Неконзистентна конфигурација не може да се објави.
AUT-04	Ј	Одвајање јавних података од evaluator кључа	Клијенту се никада не испоручују тачни одговори унапред.
AUT-05	Ј	Контролисано додавање прилога	Недозвољени тип и превелика датотека се одбијају.
AUT-06	П	Шаблони за брзу израду задатка	Копија шаблона има нови ID и не мења изворни шаблон.
AUT-07	П	Преглед ученичког приказа пре објаве	Преглед открива само оно што студент сме да види.
AUT-08	Н	Сарадничко уређивање са конфликтима	Конкурентне измене не преписују туђи нацрт без упозорења.

4.5 Објављивање, верзије и повлачење

Животни циклус лабораторијских ревизија и непроменљивост покушаја.



Слика 4.5.1. UML дијаграм стања: животни циклус ревизије лабораторије.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
REV-01	Ј	Издавање нумерисане ревизије	Свако објављивање добија нови број и snapshot дефиниције.
REV-02	Ј	Валидација пре објаве	Неважећи тип или непотпун evaluator блокира објављивање.
REV-03	Ј	Везивање покушаја за тачну ревизију	Накнадна измена задатка не мења започети покушај.
REV-04	Ј	Архивирање лабораторије	Архивирана вежба више не прихвата нове покушаје.
REV-05	П	Двостепено одобрење објаве	Аутор не може сам да одобри ревизију ако је политика то захтевала.
REV-06	П	Поређење ревизија и опис измена	Видљив је delta према претходној верзији.
REV-07	Н	Пробна објава за одабрани курс	Ограничени експеримент не мења продукциону верзију осталих курсева.

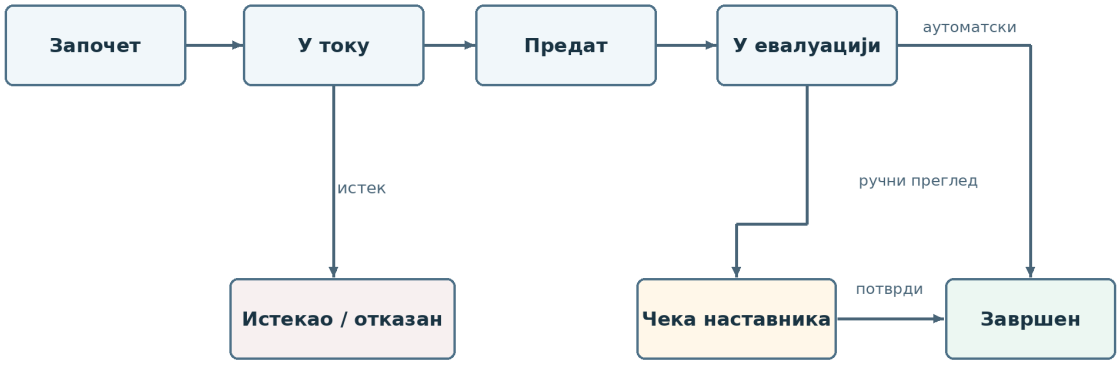
4.6 Додела вежби и приступ роковима

Наставничко додељивање лабораторија корисницима и групама.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
ASN-01	Ј	Додела лабораторије курсу	Додељивање захтева објављену ревизију.
ASN-02	Ј	Преглед доступних задатака за студента	Студент види само активне доделе својих курсева.
ASN-03	Ј	Рок и статус доступности	После истека студент не може започети нови покушај ако није дозвољено.
ASN-04	Ј	Ограничење максималног броја покушаја	Одбија се покушај изнад лимита без мењања резултата.
ASN-05	П	Додела конкретној групи	Друга група не види приватну доделу.
ASN-06	П	Изузеће и индивидуално продужење	Рок може да измени само овлашћени наставник. Свака измена остаје забележена.
ASN-07	П	Условљавање претходним задацима	Услов се проверава на серверу, не само у интерфејсу.

4.7 Покушаји, одговори и радни простор

Покретање, чување, наставак и предаја студентског рада.

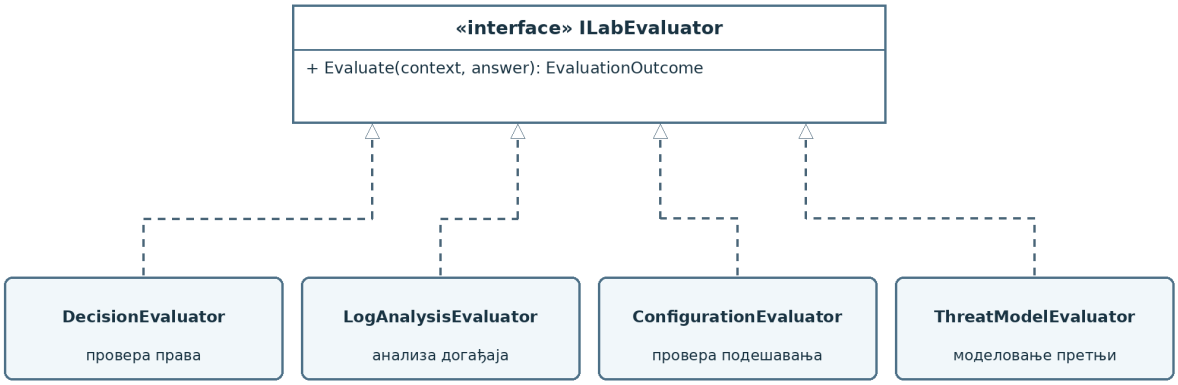


Слика 4.7.1. UML дијаграм стања: животни циклус студентског покушаја.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
ATT-01	Ј	Креирање покушаја са идемпотентним кључем	Дупли захтев не ствара дупли покушај.
ATT-02	Ј	Памћење стања и радних одговора	Након освежавања странице дозвољени напредак остаје сачуван.
ATT-03	Ј	Провера власништва над сваким покушајем	Читање/измена туђег покушаја враћа одбијање.
ATT-04	Ј	Једнократна коначна предаја	Поновљена предаја враћа исти резултат и не рачуна се два пута.
ATT-05	Ј	Конкурентне измене и верзија стања	Застарели упис не преписује новији рад.
ATT-06	Ј	Стања започет, у току, предат, завршен	Недозвољен прелаз статуса се одбија.
ATT-07	П	Временско ограничење и истек	Истек је серверски ауторитативан и не зависи од локалног сата.
ATT-08	П	Евиденција дозволених акција унутар покушаја	Поновљив след акција носи секвенцијални број.

4.8 Језгро евалуације и резултати

Типизирано оцењивање безбедносних сценарија и верзионисана повратна информација.



Слика 4.8.1. UML дијаграм класа: проширив evaluator уговор.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
EVAL-01	Ј	Избор evaluator-а према типу лабораторије	Непознат тип не покреће произвољан код.
EVAL-02	Ј	Детерминистичка провера замрзнутог улаза	Исти snapshot и одговор дају исти исход.
EVAL-03	Ј	Раздвајање интерног кључа од јавног feedback-а	Студент не може да прочита скривене одговоре кроз API.
EVAL-04	Ј	Исход: успешно, неуспешно, делимично, ручно	Вредности су ограничене дефинисаним скупом.
EVAL-05	Ј	Резултат је везан за ID покушаја и evaluator верзију	Поновљена евалуација је ревизибилна и не брише претходни запис.
EVAL-06	Ј	Грешка evaluator-а не значи пад студента	Технички неуспех се бележи засебним статусом.
EVAL-07	П	Делимично бодовање и рубрика	Сума ставки не прелази дефинисани максимум.
EVAL-08	П	Асинхрони ред послова за дуже провере	Задатак има статус, timeout и поновљиво преузимање исхода.

4.9 Ручни преглед и повратне информације

Наставнички увид, ручно образложење и решавање спорних исхода.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
REVW-01	Ј	Преглед покушаја у сопственом курсу	Наставник другог курса не може да чита податке без дозволе.
REVW-02	Ј	Додавање текстуалне повратне информације	Бележи се аутор и време уз очување претходних верзија.
REVW-03	Ј	Ручно потврђивање условног резултата	Резултат прелази из чекања у коначан статус.
REVW-04	Ј	Преглед скривених критеријума само наставнику	Ученички API не открива интерне референтне податке.
REVW-05	П	Захтев за поновни преглед	Захтев се обрађује са јасним роком и историјом одлуке.
REVW-06	П	Пакетни преглед више покушаја	Нема масовног преписивања резултата без експлицитне потврде.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
REVW-07	Н	Двоструко независно оцењивање	Постоји механизам усаглашавања различитих процена.

4.10 Напредак, компетенције и извештаји

Лични напредак, наставнички преглед и извештаји без откривања туђих резултата.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
PRG-01	Ј	Студентски преглед решених и активних вежби	Приказује се само сопствена историја.
PRG-02	Ј	Наставнички преглед курса	Агрегати су ограничени на курс који наставник води.
PRG-03	Ј	Преглед историје и варијанти покушаја	Не губе се стари резултати након нове ревизије задатка.
PRG-04	П	Мапирање лабораторија на компетенције	Једна вежба може проверавати више компетенција.
PRG-05	П	Извоз сопствених резултата	Извоз поштује ауторизацију и не открива туђе личне податке.
PRG-06	Н	Трендови и аналитика тежине задатака	Не објављују се агрегати на премалом узорку.
PRG-07	Н	Препорука следеће вежбе	Објашњив критеријум и могућност искључења персонализације.

4.11 Догађаји, ревизија и обавештења

Структурисани записи безбедносно релевантних радњи и нотификације.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
AUD-01	Ј	Ревизорски запис за пријаву и промену права	Запис има актер, догађај, време и исход.
AUD-02	Ј	Ревизорски запис за објаву ревизије	Видљив је аутор промене и ID објављене верзије.
AUD-03	Ј	Тајне и студентски одговори се не уписују у лог	Провера логова не проналази токене или скривене кључеве.
AUD-04	Ј	Корелациони идентификатор у позивима	Могуће је пратити један захтев кроз модуле.
AUD-05	П	Обавештење о доступној вежби и резултату	Понављање догађаја не ствара дупле поруке.
AUD-06	П	Наставнички преглед безбедносних догађаја	Приказани су само догађаји за које постоји овлашћење.
AUD-07	Н	Упозорења на аномалије	Правило има евидентан праг, доказ и механизам искључења.

4.12 Управљање подацима, приватност и администрација

Одржавање система, животни циклус података, резервне копије и техничке дозволе.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
ADM-01	Ј	Администраторска промена статуса налога	Свака измена права је евидентирана и подлеже контроли.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
ADM-02	Ј	Миграције шеме базе	Чиста инсталација и надоградња стварају исти модел.
ADM-03	Ј	Резервна копија и проверен поступак опоравка	Пробни restore је извршив у тестном окружењу.
ADM-04	Ј	Конфигурација преко окружења без чувања тајни у коду	Тајне нису присутне у репозиторијуму или логовима.
ADM-05	Ј	Политика задржавања и архивирања	Подаци се не бришу без правила, а приступ архиви је ограничен.
ADM-06	П	Самоуслужни извоз личних података	Извоз везан за аутентификованог корисника.
ADM-07	П	Захтев за брисање/анонимизацију у дозвољеном опсегу	Захтев не нарушава легитимни ревизорски интегритет.
ADM-08	Н	Вишекурсна администрација са делегирањем	Раздвајање административне и наставничке моћи је проверљиво.

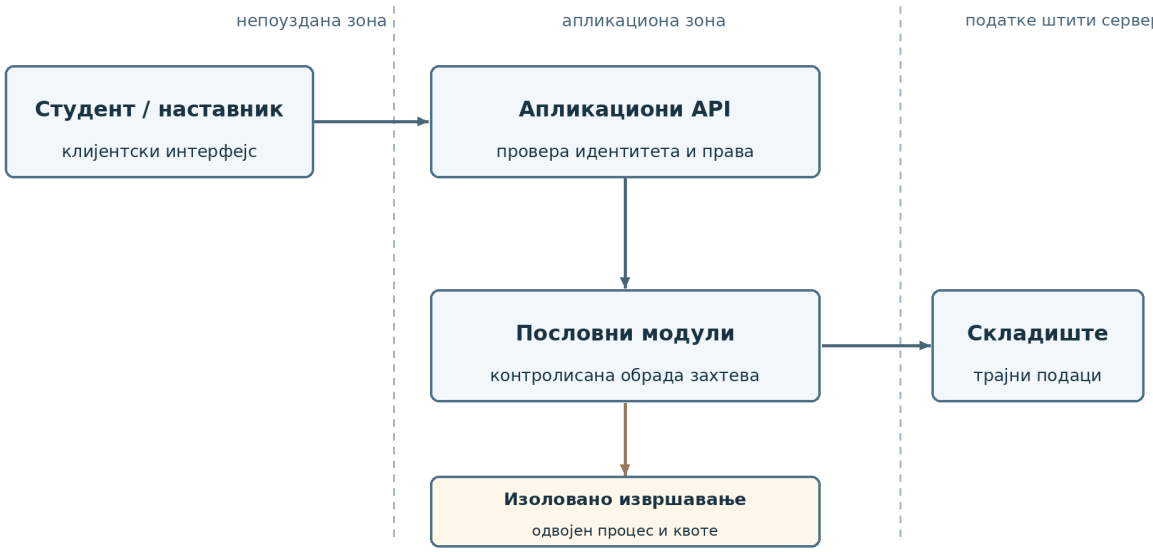
4.13 Типови интерактивних лабораторија

Додавање врста сценарија кроз заједнички уговор evaluator-а.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
TYP-01	Ј	Одлучивање о приступу (RBAC и власништво)	Тачне и недозвољене одлуке о ресурсима су проверљиве.
TYP-02	Ј	Анализа безбедносних догађаја	Идентификован је скуп релевантних догађаја и образложен налаз.
TYP-03	Ј	Процена безбедносне конфигурације	Провера открива јасно задате небезбедне параметре.
TYP-04	П	Моделовање претњи и граница поверења	Корисник повезује имовину, претњу, контролу и доказ.
TYP-05	П	Модел MFA и сесија	Није могуће користити опозвану или истеклу симулирану сесију.
TYP-06	П	Контекстуална ABAC одлука	Одлука користи субјекат, радњу, ресурс и контекст.
TYP-07	П	Одговор на инцидент и корелација	Студент идентификује редослед активности и предлаже контролу.
TYP-08	Н	Сценарији са изолованим сервисима	Извршилац не може да пређе квоте или приступи мрежи платформе.

4.14 Изоловано извршавање и техничке лабораторије

Контролисани технички сценарији који не угрожавају основни систем.



Слика 4.14.1. Границе поверења: контролисано извршавање ван основног процеса.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
RUN-01	H	Покретање само потписаног/одобреног шаблона	Корисник не може задати произвољну host команду.
RUN-02	H	Једнократно окружење по покушају	Стање других покушаја није доступно.
RUN-03	H	CPU, RAM, време и мрежне квоте	Прекорачење квоте прекида рад без пада апликације.
RUN-04	H	Ограничен приступ складишту и тајнама	Нема монтирања host тајни и осетљивих volume-а.
RUN-05	H	Истек и принудно чишћење ресурса	Након краја покушаја окружење и привремени подаци не остају активни.
RUN-06	H	Провера спремности извршиоца	Неисправан runner зауставља нова покретања уз јасну грешку.
RUN-07	H	Потписан резултат/потврда извршавања	Резултат се повезује са тачно једним покушајем.

4.15 Интеграције и проширивост

Отворене границе за будуће интерфејсе и институционалне системе.

ID	Ниво	Функционални захтев	Минимални критеријум прихватања
INT-01	П	Верзионисани јавни API уговори	Промена не руши постојеће клијенте без јасне миграције.
INT-02	П	Догађаји о завршеној лабораторији	Догађај има ID, верзију, време и идемпотентног потрошача.
INT-03	П	Извоз резултата у отвореном формату	Уз дозволу се извози минимално потребан скуп поља.
INT-04	П	Интеграција обавештења	Квар спољног сервиса не утиче на пријем предаје.
INT-05	Н	Јединствена пријава са институционалним идентитетом	Мапирање налога је јасно и може се опозвати.
INT-06	Н	Каталог додатака за лабораторије	Нови тип испуњава верзионисани уговор и пролази сертификационе тестове.
INT-07	Н	Интеграција са екстерним LMS-ом	Нема изношења података без договора и техничке дозволе.

5 Типови лабораторијских сценарија

Ово поглавље разрађује садржај лабораторијских задатака, а не уводи нове функције платформе. За сваки тип описани су подаци које студент добија, радња коју извршава и начин провере резултата. Заједнички механизми каталога, покушаја и евалуације дефинисани су у поглављу 4. Свака лабораторија користи њихове безбедносне границе и правила приступа.

5.1 Контрола приступа и власништво

Улаз: Корисник, ресурс, тражена радња и скуп дозвола. Студент одлучује да ли приступ треба дозволити и образлаже одлуку.

Провера: Решење се пореди са очекиваном одлуком за сваки захтев. Погрешно ослањање само на пријаву или улогу мора бити откривено.

Негативни случајеви: Приступ туђем ресурсу, замена ID вредности и непостојеће чланство.

Формат података: UserId, ResourceId, Action и Context. Излаз је Allow или Deny без откривања поверљивих правила.

Повезани захтеви: TYP-01, ACC-04, EVAL-02

5.2 Анализа дневника активности

Улаз: Фиксни скуп временски означених безбедносних догађаја. Студент издваја повезане записе и објашњава зашто су значајни.

Провера: Систем пореди одабране догађаје са референтним скупом, а образложење се може додатно ручно прегледати.

Негативни случајеви: Лажне узбуне, дупликати и погрешно тумачење временских зона.

Повезани захтеви: TYP-02, EVAL-01, EVAL-02

5.3 Безбедна конфигурација

Улаз: Конфигурација симулираног сервиса и правила допустивих вредности. Студент проналази небезбедна подешавања и предлаже измене.

Провера: Поређење стања пре и после измене показује да ли су нарушена правила исправљена.

Негативни случајеви: Дозвољени изузеци, недостајућа подешавања и међусобно противречне политике.

Повезани захтеви: TYP-03, AUT-03, EVAL-02

5.4 Границе поверења и модел претњи

Улаз: Опис система, компоненте, токови података и пословна имовина. Студент повезује претње, границе поверења и контроле.

Провера: Машински се проверавају односи у моделу. Наставник користи рубрику за квалитет образложења.

Негативни случајеви: Изостављена граница поверења, контрола на погрешном месту и претња без провере.

Повезани захтеви: TYP-04, AUT-02, REVW-02

5.5 MFA и управљање сесијама

Улаз: Симулирани ток пријављивања са факторима и стањима сесије. Студент одређује дозвољене прелазе и предузима радње опозива.

Провера: Систем утврђује да ли се истекле и опозване сесије одбијају, а обавезни фактор не прескаче.

Негативни случајеви: Поновна употреба опозване сесије и заобилажење другог фактора.

Повезани захтеви: TYP-05, IDN-06, IDN-07

5.6 Контекстуална ауторизација

Улаз: Субјекат, радња, ресурс, атрибути и контекст захтева. Студент процењује право приступа за више услова.

Провера: Одлуке се пореде са правилом које укључује улогу, власништво, време и статус ресурса.

Негативни случајеви: Недостајући атрибут, измењен контекст и погрешна подразумевана дозвола.

Повезани захтеви: TYP-06, ACC-08, EVAL-02

5.7 Детекција и одговор на инцидент

Улаз: Безбедносни догађаји и опис контекста. Студент издваја повезане показатеље, одређује приоритет и бира следећи корак.

Провера: Поред препознавања релевантних догађаја, проверава се редослед реаговања и образложење предложене контроле.

Негативни случајеви: Лажна узбуна, непотпун доказ и пропуштена ескалација.

Повезани захтеви: TYP-07, AUD-01, REVW-02

5.8 Изолована лабораторијска окружења

Улаз: Унапред одобрен лабораторијски шаблон са ограниченим ресурсима и дозвољеним корацима. Студент извршава задатак само у изолованом окружењу.

Провера: Платформа бележи исход тачно једног покушаја и потврђује поштовање временских, процесорских и мрежних ограничења.

Негативни случајеви: Произвољна команда домаћина, прекорачење квоте и приступ мрежи основне платформе.

Повезани захтеви: TYP-08, RUN-01, RUN-03

6 Кључни случајеви употребе и токови

Описани токови повезују више већ дефинисаних функционалности. Сваки случај употребе показује редослед провера, промену стања и поступање при неуспеху. Ознаке UC служе за опис интеракција и не представљају нове функционалне захтеве поред каталога из поглавља 4.

6.1 UC-01 Студент започиње лабораторију

Предуслов: Активан налог, уписан курс, објављена ревизија, неисцрпљен лимит.

Основни ток: Студент бира лабораторију. Сервер проверава право приступа, рок и преостали број покушаја, затим креира Attempt везан за непроменљиву ревизију и враћа радни приказ.

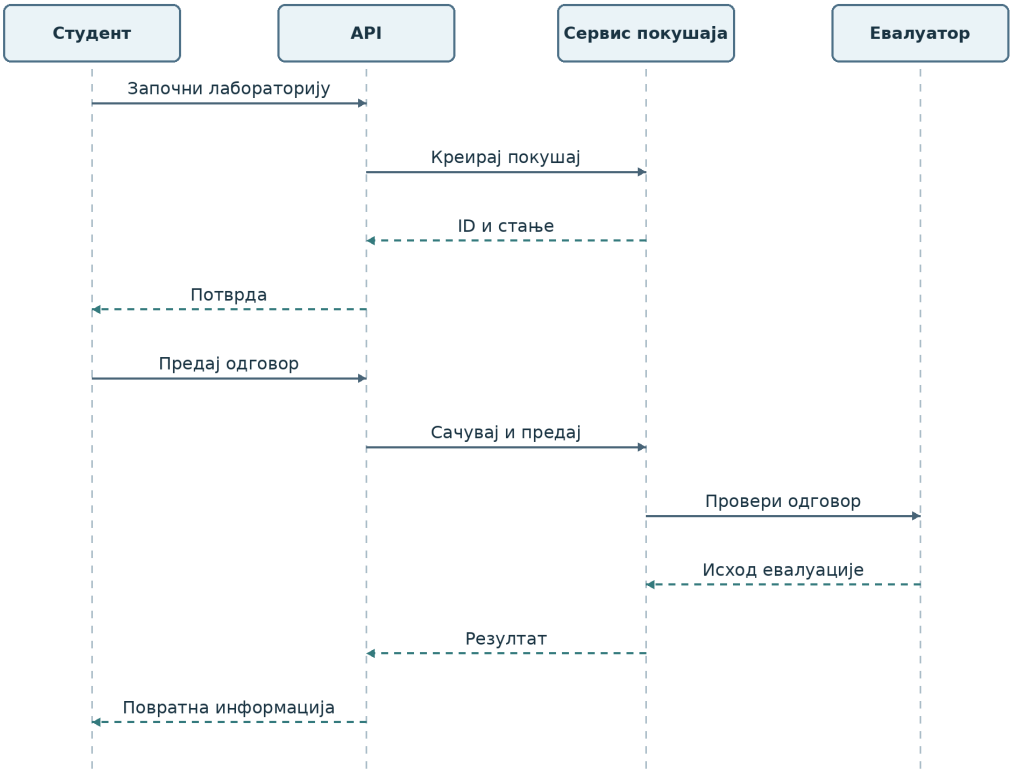
Алтернативни и негативни ток: Недозвољен курс, истек, дупли клик или блокиран налог враћа безбедан одговор без дуплирања.

6.2 UC-02 Студент предаје решење

Предуслов: Покушај припада студенту и у стању је У току.

Основни ток: Сачува се одговор, покушај пређе у Предат и покрене се одговарајући evaluator.

Алтернативни и негативни ток: Поновљена предаја враћа претходно забележени исход. Предаја туђег или недозвољеног покушаја се одбија.



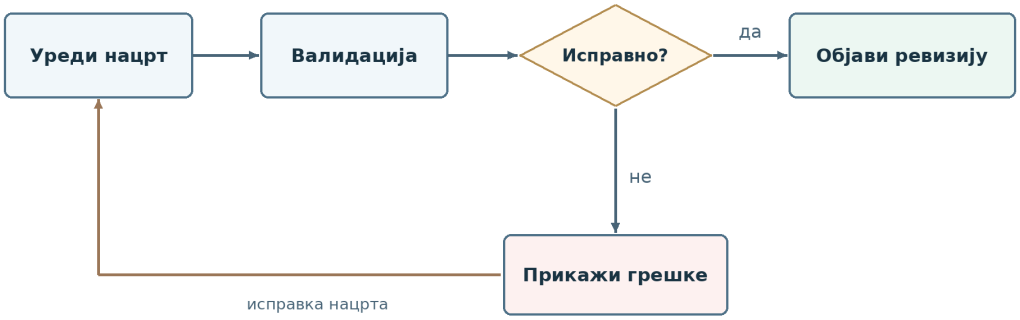
Слика 6.2.1. UML дијаграм секвенце: почетак, предаја и аутоматска евалуација.

6.3 UC-03 Наставник објављује лабораторију

Предуслов: Аутор има дозволу за објављивање и нацрт задовољава валидирана правила.

Основни ток: Валидација, преглед, издавање непроменљиве ревизије, постављање у курс.

Алтернативни и негативни ток: Непотпуна шема или недозвољен аутор не могу да објаве лабораторију.



Слика 6.3.1. UML дијаграм активности: валидација и објављивање ревизије.

6.4 UC-04 Наставник ручно проверава резултат

Предуслов: Резултат је на ручном прегледу, наставник има чланство.

Основни ток: Наставник чита дозвољене податке, примењује рубрику, бележи образложење и потврђује.

Алтернативни и негативни ток: Наставник без овлашћења за конкретан курс нема увид. Свака измена резултата остаје у историји ревизија.

6.5 UC-05 Администратор опозива налог

Предуслов: Постоји техничка дозвола, разлог се бележи.

Основни ток: Администратор мења статус налога. Систем опозива активне сесије и евидентира радњу.

Алтернативни и негативни ток: Студент не може позвати административну акцију.

6.6 UC-06 Систем аутоматски оцењује

Предуслов: Evaluator је регистрован за тип и ревизију.

Основни ток: Чита immutable snapshot, резултат чува одвојено, враћа дозвољени feedback.

Алтернативни и негативни ток: Техничка грешка евалуатора не сме се третирати као нетачан студентски одговор. Прекорачење временског ограничења бележи се као засебан исход.

6.7 UC-07 Додавање новог типа лабораторије

Предуслов: Нови тип лабораторије има дефинисану шему података, валидирана правила и регистровану имплементацију уговора ILabEvaluator.

Основни ток: Систем проверава шему и компатибилност евалуатора, региструје тип и дозвољава креирање лабораторије која користи тај тип.

Алтернативни и негативни ток: Непознат тип, некомпатибилан уговор или неважећа конфигурација спречавају објављивање. Постојеће ревизије и покушаји остају непромењени.

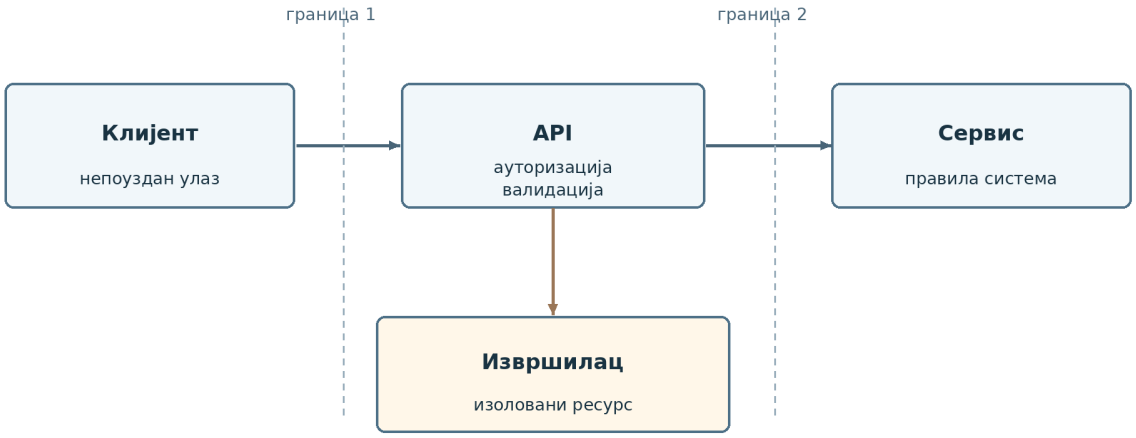
7 Безбедносни и нефункционални захтеви

Безбедносни захтеви представљају проверљиве услове прихватања. Не могу бити испуњени само описом у документацији. Контроле се примењују на серверу и доказују позитивним и негативним аутоматизованим тестовима.

ID	Захтев	Пример провере
SEC-01	Серверска ауторизација за сваку осетљиву операцију	Покушај IDOR приступа туђим ресурсима је одбијен.
SEC-02	Безбедно чување лозинки и тајни	Нема тајни у репозиторијуму, API одговору или логовима.
SEC-03	Сигурни колачићи/сесије, CSRF за cookie аутентикацију	Опозвана сесија више није употребљива. Покушај CSRF злоупотребе мора бити одбијен.
SEC-04	Ограничење покушаја и злоупотребе API	Прекомерни захтеви се контролисано одбијају.
SEC-05	Валидација улаза и безбедан приказ текста	Злонамеран унос не извршава скрипту ни упит.
SEC-06	Заштита upload-а и привремених средстава	Дозвољени су само типови и величине из политике.
SEC-07	Задржавање и ограничен приступ личним подацима	Сваки извоз и архивска операција пролазе проверу права.
SEC-08	Непроменљивост историјског покушаја и ревизије	Промена лабораторије не мења стари snapshot.
SEC-09	Нема јавног извршавања рањивих сервиса у основном окружењу	Постоје тестови који доказују изолацију и мрежне границе.
OPS-01	Поновљиво покретање из чистог репозиторијума	Документована изградња и миграције пролазе на чистом окружењу.
OPS-02	Интеграциони и јединични тестови	Критична правила и негативни токови обухваћени су тестовима.
OPS-03	Континуирана интеграција и провера зависности	Неуспешни тестови блокирају интеграцију промене.
OPS-04	Поновљив backup/restore тест	Опоравак враћа интегритет дозвољеног скупа података.
OPS-05	Верзионисани API и миграције	Нова верзија не укида јавни уговор без миграционог плана.
OPS-06	Перформансе уз наведени профил оптерећења	Граничне вредности одређују се мерењем под документованим профилом оптерећења.
OPS-07	Приступачност и јасне поруке о грешци	Основне форме доступне су преко тастатуре. Поруке о грешци не откривају тајне.
OPS-08	Структурисано логовање и праћење грешака	Свака критична операција има корелациони ID.
OPS-09	Временске зоне и server-side рокови	Провера рока не зависи од сата прегледача.
OPS-10	Посматрање здравља процеса и базе	Здравствена провера не открива интерну конфигурацију.

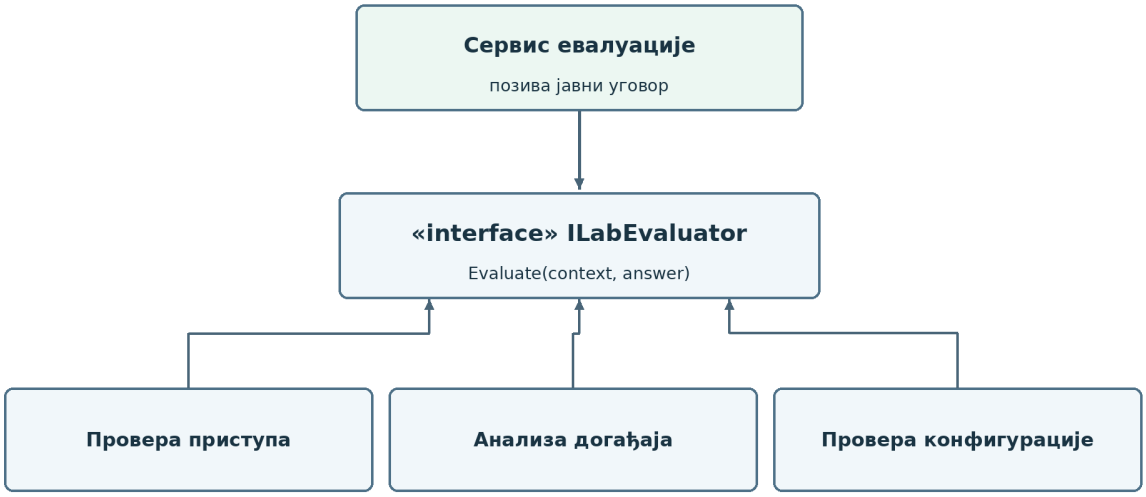
7.1 Претње и границе поверења

Кључне претње су неовлашћен приступ туђим покушајима, крађа наставничких овлашћења, изношење тајних кључева евалуације, злоупотреба прилагања датотека, исцрпљивање ресурса и пробијање границе између демонстрационог окружења и платформе. Сваки модул одржава табелу претња–контрола–тест–доказ.



Слика 7.1.1. Границе поверења између клијента, сервиса и изолованог извршавања.

7.2 Уговор проширивости evaluator-a



Слика 7.2.1. UML приказ повезивања типова лабораторија преко заједничког уговора.

Интерфејс ILabEvaluator прихвата контекст конкретне објављене ревизије и студентски одговор, а враћа структуриран EvaluationOutcome. Тип evaluator-a и његова верзија морају бити забележени. Непроверени додатак не постаје аутоматски поуздани део система.

8 Проверљивост, тестирање и прихватање

Услов прихватања функционалности чине проверен позитиван и негативан сценарио, исправна ауторизација и аутоматизовани тестови одговарајућег уговора. За измене података обавезна је проверљива миграција. Приказ корисничког интерфејса без потврде пословних и безбедносних правила није довољан.

8.1 Структура тест-сценарија

Поље	Садржај
Requirement ID	На пример ATT-03.
Предуслов	Два корисника са различитим власништвом над покушајима.
Акција	Корисник A покушава да прочита Attempt корисника B преко API позива.
Очекивано	Приступ је одбијен, одговор не садржи садржај туђег покушаја.
Доказ	Име теста, датум, верзија кода и извршни резултат.

8.2 Интеграционе и регресионе провере

- Изградња целог решења и покретање свих аутоматизованих тестова.
- Провера смерова зависности: унутрашњи пословни модул не познаје технички адаптер.
- Негативне провере IDOR, недозвољене промене улоге, дупле предаје и измене објављене ревизије.
- Провера компатибилности постојећих API позива и миграција.
- Проверљив поступак покретања са тестним подацима, без стварних студентских налога и тајни.

9 Речник појмова

Појам	Значење
Laboratory	Трајна логичка целина лабораторије.
LabRevision	Објављен или припремљен снимак садржаја, шеме и evaluator уговора.
Attempt	Један конкретан студентски покушај везан за ревизију.
Evaluator	Стандардизована компонента за проверу структурираних одговора.
Assignment	Додела ревизије курса, групи или студенту са роковима и правилима.
Audit event	Структурисан запис безбедносно значајне радње без тајни.
Modularni monolit	Једна апликација са логички изолованим модулима и експлицитним уговорима.
Изоловани runner	Опциона компонента за ограничено извршавање техничких лабораторија.
J/П/H	Основна, проширена и инфраструктурно захтевна функционалност, према зависностима система.

При промени нормативног захтева потребно је документовати његов утицај на постојеће функције, податке, тестове и јавне уговоре. Стабилни идентификатори обезбеђују следљивост захтева и историју измена.